Validated-by-Design

A Shift-Left Approach to Computer System Validation for Cloud-Native GxP Platforms

White-Paper · Paper 3 of 3 — Regulatory & Implementation Guide

Authors: Steven Schmidt, Gupta Tulluri, Corrado Iorizzo

Audience: CSV and Validation leads · Business and IT Quality and GxP leaders · Regulatory Affairs and Compliance · Data Integrity leads · Internal Audit and inspection-readiness teams

Table of Contents

About This Paper 3
1. Regulatory Foundations and Scope 4
2. Regulatory Mapping 6
3. Implementing Shift-Left CSV 8
4. Inspection Readiness 11
5. AI Workloads and the Draft Annex 22 12
6. Risks and Mitigations 14
7. Conclusion and Way Forward 16
8. References and Regulatory Sources 17

About This Paper

This is Paper 3 of a three-part series on Shift-Left Computer System Validation, written so each paper can be read on its own.

The shared thesis across the series: retrospective CSV practices can struggle to keep assurance aligned with cloud-native GxP platforms; the proposed response is to engineer governed controls and evidence capture into the architecture, while retaining intended-use assessment, risk-based judgement, exceptions, change impact, and Quality accountability.

The series is organised by audience:

- **Paper 1 — Vision & Operating Model:** for executive sponsors and Business and IT leaders across Quality, GxP, Operational Excellence, and Data Platforms. It explains the vision, operating model, governance, adoption roadmap, and grounded conclusion.
- **Paper 2 — Technical Reference Architecture:** for architects and platform teams. It develops the architecture principles, policy-as-code, lineage and consistency patterns, and reference architecture.
- **Paper 3 — Regulatory & Implementation Guide (this paper):** for CSV, Quality, and Regulatory teams. It develops the regulatory mapping, implementation and inspection readiness, AI workloads, and risks and mitigations.

Papers 1 and 2 describe what the model is and how it is built. This paper answers the questions a CSV lead, a Quality head, or an inspector will ask next: which regulatory expectations apply, what evidence the platform can contribute to each, which judgements stay with people, which validation deliverables remain, how the model is presented at inspection, and what could make it fail. The core model does not create new regulatory requirements. It maps Shift-Left CSV to requirements already in force and, where relevant, considers emerging expectations from draft guidance separately.

License and Disclaimer

Copyright © 2026 Corrado Iorizzo, Steven Schmidt, and Gupta Tulluri. Except where otherwise noted, this work is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0): https://creativecommons.org/licenses/by/4.0/.

The views expressed are those of the authors and do not necessarily represent those of Microsoft, Lonza, or their respective affiliates. References to products or services do not constitute endorsement or establish regulatory compliance. This paper is provided for informational purposes and does not constitute legal, regulatory, or quality-system advice. Each regulated organisation remains responsible for interpreting the applicable requirements for its own products, processes, and systems.

1. Regulatory Foundations and Scope

> **Shift-Left CSV does not change what regulators require; it changes how and when the evidence for those requirements is produced. Binding requirements, regulatory guidance, industry guidance, and draft texts carry different weight and must not be treated as interchangeable.**

This paper is written for organisations that manufacture medicinal products or active substances under EU GMP (EudraLex Volume 4), for organisations subject to US FDA predicate rules and 21 CFR Part 11, and for those inspected by PIC/S-aligned authorities. Other GxP domains — clinical, laboratory, distribution, and pharmacovigilance — apply the same principles through their own instruments; this paper does not map them clause by clause, and readers in those domains should confirm the applicable requirements.

How the sources in this paper should be read

Source	Status	How this paper uses it
EudraLex Volume 4, Annex 11 — Computerised Systems (2011)	EU GMP guideline in force	Primary clause references for the regulatory mapping in Section 2.
EudraLex Volume 4, Chapter 4 — Documentation; Annex 15 — Qualification and Validation	EU GMP guidelines in force	Documentation principles, and qualification and validation expectations for the shared platform baseline.
Draft revised EudraLex Volume 4, Chapter 4 – Documentation (2025)	Draft – not adopted	Emerging expectations for electronic documentation, data governance, and lifecycle management. Referenced for forward-looking alignment, not as a current regulatory requirement.
21 CFR Part 11 — Electronic Records; Electronic Signatures	US regulation; applies to records and signatures required by predicate rules	Controls for closed systems (§11.10), signature manifestation and linking (§§11.50, 11.70), and electronic-signature components and controls (§§11.100–11.300).
FDA, Part 11, Electronic Records; Electronic Signatures — Scope and Application (2003)	FDA guidance	FDA's narrow interpretation of Part 11 scope and its risk-based approach to validation, audit trails, copies, and record retention.
FDA, Data Integrity and Compliance with Drug CGMP — Questions and Answers (2018); MHRA, 'GxP' Data Integrity Guidance and Definitions (2018); PIC/S PI 041-1 (2021)	Regulatory guidance	Data-integrity and data-governance expectations, including ALCOA+ principles.
ICH Q9(R1) — Quality Risk Management (2023)	ICH guideline, adopted by EMA and FDA	Basis for risk assessment, proportionate effort, and the risk ratings in Section 6.
ISPE GAMP® 5 Second Edition (July 2022)	Non-binding industry guidance	Lifecycle approach, critical thinking, supplier leverage, and categorisation applied at component level.
FDA, Computer Software Assurance for Production and Quality Management System Software (February 2026)	FDA guidance for medical-device production and quality system software under 21 CFR Part 820	Referenced only for its risk-based assurance principles. It is not a requirement for pharmaceutical GMP computerised systems.
Draft revised Annex 11, draft revised Chapter 4, and draft new Annex 22 — Artificial Intelligence (consultation 7 July–7 October 2025)	Drafts; not confirmed as adopted at the time of writing	Direction of travel only, identified as draft wherever used. Not treated as a current requirement.

What Shift-Left CSV does not change

- **Predicate rules decide which records are GxP records.** Platform evidence becomes a regulated record only where a predicate rule or the organisation's own procedures make it one; Section 3 explains why that classification must be made deliberately.
- **Computerised systems are validated for their intended use.** Each GxP application requires assurance appropriate to its intended use and applicable predicate-rule requirements. The platform contributes reusable qualified controls and evidence, but does not by itself establish the application's fitness for intended use. 21 CFR Part 11 applies where the relevant electronic records or electronic signatures are within scope.
- **The regulated organisation remains accountable.** Use of a cloud provider, a platform team, or automated controls does not transfer responsibility for product quality, data integrity, or compliance. Under Annex 11 §3, formal agreements with third parties should state their responsibilities clearly.
- **Quality approves.** The validation strategy, acceptance of residual risk, release for GxP use, and conclusions from periodic evaluation remain accountable decisions of the regulated organisation, with Quality oversight and approval as defined by the QMS. Automated controls provide evidence to support these decisions, they do not replace human accountability.

Regulatory currency

> **Note on regulatory currency.** Clause references in this paper follow the current EU Annex 11 (2011). A revised Annex 11, a revised Chapter 4, and a new Annex 22 on Artificial Intelligence were published for joint EU and PIC/S consultation on 7 July 2025; the consultation closed on 7 October 2025. At the time of writing, adoption of the final texts had not been confirmed. Readers should check the current status in EudraLex Volume 4 before relying on any clause number. The drafts expand expectations for supplier and service management (including cloud services), identity and access management, and audit trails — themes this paper addresses — but organisations should gap-assess against them rather than implement draft text as if it were final.

2. Regulatory Mapping

> **Each regulatory expectation stays the same. Platform controls can contribute more current evidence towards it, but every row retains a judgement that belongs to accountable people and a Quality decision that is not automated.**

The table maps the computerised-system expectations that CSV and Quality teams work with most often. Read it in three parts. Traditional evidence is what a document-led validation package typically contains. Platform-generated evidence is what a governed, validated-by-design platform can produce continuously, as described in Paper 2. Retained human judgement is what stays with accountable people regardless of automation. Platform-generated evidence supports the requirement; whether it is sufficient for a given workload is a documented Quality decision (Section 3.2).

Requirement	Regulatory source	Traditional evidence	Platform-generated evidence	Retained human judgement and Quality decision
Risk management	Annex 11 §1; ICH Q9(R1); GAMP 5	Risk assessment per system; risk-based test rationale.	Control catalogue linked to risks; residual-risk register; exception and deviation trends.	Identifying risks, judging severity, and accepting residual risk (Quality with the system owner).
Validation	Annex 11 §4; Annex 15; 21 CFR §11.10(a); GAMP 5	Validation plan, URS, specifications, IQ/OQ/PQ, traceability matrix, validation report.	Requirement-to-control traceability; automated test and deployment records; evidence-completeness reports.	Intended use, validation strategy, acceptance criteria, and approval of the validation report and release.
Infrastructure qualification	Annex 11 Principle; Annex 15; GAMP 5	IQ protocol and report, build records, configuration exports.	Versioned baseline-as-code; automated qualification checks on each deployment; policy-compliance history.	Approving the baseline and material changes; deciding whether inherited qualification applies to a workload.
Suppliers and service providers	Annex 11 §3; EU GMP Chapter 7; GAMP 5	Supplier questionnaire, audit report, quality agreement, certificates.	Service-to-control mapping; shared-responsibility records; supplier change notices with impact assessments.	Supplier assessment conclusion, agreement terms, and acceptance of residual supplier risk.
Data accuracy, storage, and integrity	Annex 11 §§5–7; 21 CFR §11.10(b)–(c); ALCOA+ (MHRA 2018; PIC/S PI 041-1)	Data-integrity assessments, reconciliation reports, audit-trail sampling.	Lineage records, schema versions, ingest fidelity checks, data-quality results, consistency-window monitoring, backup and restore records.	Data criticality, acceptable consistency windows, and disposition of quarantined data.
Audit trails	Annex 11 §9; 21 CFR §11.10(e)	Audit-trail configuration, sample exports, periodic review.	Attributed, time-stamped change events captured at source and retained with integrity protection; review queues.	What must be audit-trailed (including reason for change), and risk-based audit-trail review and its conclusions.
Change and configuration management	Annex 11 §10; GAMP 5	Change request, impact assessment, test scripts, approvals, release notes.	Pull requests, automated tests, deployment records, configuration differences, approval records.	GxP impact assessment, change classification, and approval of significant changes.
Periodic evaluation	Annex 11 §11	Periodic review report.	Control dashboards, exception ageing, drift reports, evidence-completeness metrics.	The conclusion that the system remains in a validated state, and any corrective action.
Security and access	Annex 11 §12; 21 CFR §11.10(d), (g)	Access matrix, access requests, periodic access reviews.	Identity and role assignments, privileged-access records, policy evaluations, denied-deployment records.	Role design, segregation of duties, access approvals, and review of privileged access.
Incident management	Annex 11 §13	Incident and deviation records.	Alerts, incident timelines, and platform telemetry linked to affected workloads.	Root cause, GxP impact, and corrective and preventive action.

Requirement	Regulatory source	Traditional evidence	Platform-generated evidence	Retained human judgement and Quality decision
Electronic signatures	Annex 11 §14; 21 CFR §§11.50, 11.70, 11.100–11.300	Signature configuration, procedures, training records.	Signature events bound to the signed record with name, date and time, and meaning; authentication records.	Which approvals are GxP signatures, their meaning, and the organisation's legal commitment to them (Section 3.4).
Batch certification	Annex 11 §15	Certification records.	Evidence that only authorised Qualified Persons can certify, and certification events.	The Qualified Person's certification decision.
Business continuity and archiving	Annex 11 §§16–17	Continuity plan, restore tests, archive procedures.	Backup and restore-test records, resilience test results, archive integrity and readability checks.	Acceptable recovery objectives for the business process, and retention and archiving decisions.

Where platform evidence is stronger

Platform-generated evidence adds most where the control objective depends on the current operating state of the system. A periodic access review shows that a review took place; a policy-driven access model can also show whether unauthorised assignments were prevented, whether privileged access was time-bound, and whether exceptions exceeded their approved window. An IQ report documents how an environment was built; a baseline that is re-evidenced on every deployment can show that the qualified configuration is still in force. In these areas the evidence is more current and more complete — provided the controls that generate it are themselves qualified and governed (Section 3.3).

Where it is equivalent, in a new form

Inspectors will still expect a validation strategy, a traceability matrix, test evidence, and a validation report. The shift-left model does not argue that these disappear. It shows that traceability is maintained from requirement to control objective, policy definition, test, deployment, and evidence record, and that the familiar artefacts are generated from those links rather than maintained by hand. Where the control objective, traceability, integrity and approval requirements are met, platform-generated records can replace or reduce specific document-based evidence. Intended-use and application-specific testing still remain where required.

Where it adds little

Some expectations are met mainly through people and procedures: training and qualification of personnel, adherence to SOPs, scientific judgement in investigations, supplier audits, and the Qualified Person's decision. Platform evidence can support the record-keeping around these activities, but it cannot demonstrate the judgement itself. Organisations should not over-engineer automation for controls whose assurance lies in human competence and oversight.

3. Implementing Shift-Left CSV

> **Implementation starts from the validation deliverables CSV teams already know. What changes is that much of their content is generated by governed platform controls, and that reuse of platform evidence becomes a documented, workload-specific decision rather than an assumption.**

3.1 Validation deliverables in the shift-left model

No core deliverable disappears. The table shows how each one changes and who owns it, using the roles defined in Paper 1.

Deliverable	What changes in the shift-left model	Owner (Paper 1 roles)
Validation strategy or plan	States which evidence is platform-generated, and which remains document-based, and how inherited controls are assessed. Written once for the platform and referenced by each workload.	QA/CSV (accountable); Business Process / System Owner (consulted)
Intended-use and GxP impact assessment	Unchanged in substance, and required for every workload. It determines how much platform evidence can be reused.	Business Process / System Owner
Risk assessment	Performed under ICH Q9(R1) and linked to the control catalogue, so each risk shows its controls and their evidence.	QA/CSV with the Business Process / System Owner
User requirements	Traced to control objectives and policies as well as to tests.	Business Process / System Owner; Application Engineering
Supplier assessment	Risk-based assurance across all consumed services, kept current as services change (Section 3.5).	QA/CSV; Platform Engineering
Platform qualification	The shared platform baseline is qualified for reuse and continuously maintained under change control, with approved evidence linked to the applicable baseline and version. Quality oversight and approval apply as defined by the QMS, informed by Annex 15 principles.	Platform Engineering (responsible); QA/CSV (accountable)
Testing	A risk-based mix of scripted and unscripted testing, consistent with GAMP 5 critical thinking. Automated tests run in controlled pipelines, and their results are retained as records.	Application Engineering; QA/CSV review
Traceability matrix	Generated from requirement–control–test–evidence links rather than maintained by hand.	Application Engineering; QA/CSV
Validation summary report and release	Draws on evidence-completeness reports. Release for GxP use remains a signed Quality decision.	QA/CSV
Operational procedures	Change, incident, access review, backup and restore, and periodic evaluation procedures reference the automated controls and define what people must review.	QA/CSV; Platform and Application Engineering

3.2 Deciding when platform evidence can be inherited

Paper 2 describes the determining layer: intended use, GxP impact, risk assessment, and validation strategy decide how much of the platform's reusable evidence a workload may rely on. In practice, CSV teams need a repeatable procedure and a record. For each workload, before go-live:

1. Confirm that each control to be inherited is in the approved control catalogue, is qualified, and is in its current approved version.
2. Confirm that the workload's intended use and GxP impact fall within the scope for which the control was qualified.
3. Assess residual risk specific to the workload – intended use, process criticality, data criticality, interfaces, configuration, user roles, and any controls that override or extend the platform baseline.

4. Record gaps as exceptions, each with an owner, rationale, compensating control, and expiry.
5. Document the outcome in an approved control inheritance record that references the approved platform control set and baseline version. Record non-applicable controls, exceptions, and workload-specific controls without duplicating the complete platform control inventory.
6. Re-assess when the inherited control, the workload's intended use, or the underlying supplier service changes.

GAMP categorisation is applied at the appropriate component level as one input to this assessment, together with intended use, complexity, and risk; it is not inferred from the platform layer a component sits on. Inheritance reduces duplicated qualification effort. It never transfers accountability, and two workloads on the same baseline may legitimately reach different validation strategies.

3.3 The evidence store as a GxP system

If platform-generated evidence supports GxP decisions, the system that holds it must be fit for that purpose. Paper 2 states that the validator is itself validated; for CSV teams this translates into concrete expectations:

- **Record classification.** Decide which evidence records are GxP records under predicate rules or internal procedures, and therefore subject to Part 11 and Annex 11 controls, and which are supporting operational data. Record the decision.
- **Validation for intended use.** Validate the evidence store and the pipelines that feed it, proportionate to the decisions they support.
- **Integrity and segregation of duties.** Use append-only or immutable storage with integrity checks, least privilege and segregated privileged administration. Any authorised modification or deletion capability should be tightly controlled, independently reviewed and fully auditable.
- **Reliable time.** Synchronise time sources so that event timestamps are accurate and comparable across systems.
- **Retention, backup, and archiving.** Retain evidence for at least the longest applicable record-retention period, test backup and restore regularly (Annex 11 §7.2), and keep archived evidence readable (Annex 11 §17).
- **Readable copies.** Ensure inspection-ready access and the ability to produce accurate, complete and human-readable copies, and where appropriate electronic copies, that preserve the content and meaning of the records, consistent with applicable predicate rules and FDA Part 11 guidance.

3.4 Electronic signatures

A workflow approval or a pull-request approval is not automatically an electronic signature. Organisations should first decide which approvals constitute GxP signatures — for example, approval of a validation report, release for GxP use, or approval of a regulated record — and design those signatures to meet the requirements in full:

- **Manifestation and linking.** Each signature shows the signer's printed name, the date and time, and the meaning of the signature (21 CFR §11.50), and is linked to its record so that it cannot be excised, copied, or otherwise transferred to falsify the record (§11.70). Annex 11 §14 sets equivalent expectations: the same impact as a handwritten signature within the company, a permanent link to the record, and the time and date of signing.
- **Signature components and controls.** Electronic signatures are unique to one individual, and the individual's identity is verified before a signature is assigned (§11.100). Non-biometric

signatures use at least two distinct identification components (§11.200), with controls over identification codes and passwords (§11.300).

- **Certification to FDA.** Before using electronic signatures for records within Part 11 scope, the organisation certifies to FDA that its electronic signatures are intended to be the legally binding equivalent of handwritten signatures (§11.100(c)).

Where approvals in engineering tools — for example, approval of a policy change — serve as the GxP approval record, the same analysis applies. Where they do not, they remain change-control approvals supported by the organisation's change procedure.

3.5 Supplier assurance for cloud services

For hyperscale cloud providers, supplier assurance should follow a documented, risk-based approach. Depending on criticality and practical access, this may combine direct supplier assessment, independent third-party audit reports and certifications, contractual commitments, a documented shared-responsibility model recording which controls the supplier operates and which the customer retains, and ongoing service monitoring rather than a one-time assessment. The regulated organisation remains accountable for deciding whether this evidence is sufficient for the intended GxP use.

Certifications such as ISO/IEC 27001 or SOC 2 reports address information security and service controls; they inform the assessment but do not by themselves demonstrate suitability for GxP use. Agreements should cover the responsibilities stated in Annex 11 §3 and, where relevant, support for inspections, notification of changes and security incidents, data location, and exit arrangements that keep data retrievable in readable form for the full retention period. The draft revised Annex 11 expands these expectations for service providers and is a useful gap-assessment reference.

3.6 Change control, requalification, and periodic evaluation

Cloud services change beneath the customer. Sustaining the qualified state therefore requires a defined loop: monitor supplier change notifications and service-health channels; decide in advance which services and change types require GxP impact assessment — for example, any service listed in the control catalogue; assess each relevant change; and requalify the affected baseline where the impact is material. The organisation's own platform changes follow its change-control procedure, with infrastructure-as-code changes reviewed, tested, and approved like any other controlled configuration.

Periodic evaluation under Annex 11 §11 is performed at a risk-based frequency. Dashboards, exception ageing, and evidence-completeness metrics make the evaluation faster and better informed, but the evaluation itself remains a documented, reviewed, and approved conclusion that the system remains in a validated state.

4. Inspection Readiness

> **Inspectors assess whether a system is under control and whether the organisation understands it. The shift-left model is inspection-ready only when accountable people can explain it, records can be produced in readable form, and every automated control traces to a requirement and an owner.**

The inspector narrative

Paper 1 makes a draft inspector narrative a deliverable of the first adoption phase. It should be a short, controlled document that explains the assurance model in plain language: its scope; which evidence is platform-generated and which is document-based; how inheritance decisions are made and recorded; how the integrity of the evidence store is assured; and who is accountable for each decision. Site inspection-readiness leads and Quality leadership should be briefed on the model well before an inspection, so that it is never presented for the first time in front of an inspector.

Preparing for typical inspection requests

Inspector request	What to present	Watch-outs
Show me the validation status of this system.	The approved validation report, the control inheritance record, and the current evidence-completeness report.	A dashboard is not a validation report. Present approved, dated, version-controlled records.
Who has access, and how is it controlled?	Access procedure, current role assignments, access-review records, and privileged-access records.	Show the review decisions, not only the underlying data.
Show me the audit trail for this record.	The record-level audit trail in readable form, produced by the system.	Audit trails should not depend on engineering scripts written during the inspection.
How do you control changes to the platform?	Change procedure and a sample of changes, including infrastructure-as-code changes and their impact assessments.	Be ready to explain emergency changes and how they were reviewed afterwards.
How do you know your cloud supplier is suitable?	Supplier assessment, agreements, shared-responsibility matrix, and recent change impact assessments.	Certificates alone are not a supplier assessment.
How is data integrity assured across this data flow?	Lineage for a sample record, data-quality and reconciliation evidence, and dispositions of quarantined data.	Walk one real record end to end.
How do you know the automated controls work?	Qualification of the policy engine and evidence store, policy test results, and control-performance metrics.	Expect the question “who checks the checker?”
Show me your exceptions.	The exception register with owners, rationale, compensating controls, and expiry dates.	Expired exceptions, or exceptions renewed without fresh justification, are likely findings.

Demonstrating live systems

Where evidence is held in platform tools, prepare controlled, pre-agreed reports and queries in advance, and train the people who will run them. Any copy provided to an inspector should be accurate and complete, and should be retained in the inspection record. Avoid improvising technical queries during an inspection; unexpected results are difficult to explain under time pressure.

Mock inspections

Run at least one mock inspection on the pilot workload before relying on the model, led by someone independent of the delivery team and experienced in GxP inspections. Use the requests above as a starting point, record findings and responses, and update the inspector narrative and evidence pack accordingly. Paper 1 includes this as a success criterion for the Prove phase.

5. AI Workloads and the Draft Annex 22

> **The draft Annex 22 proposes a clear boundary between critical and non-critical AI use. A validated-by-design platform can enforce and evidence that boundary, but the text remains a draft and should guide preparation rather than be treated as settled requirement.**

Status and scope

The draft Annex 22 was published for consultation on 7 July 2025, alongside the draft revised Annex 11 and Chapter 4, as additional guidance for computerised systems in which AI models are used; the consultation closed on 7 October 2025. At the time of writing, adoption of the final text had not been confirmed. Today, AI-enabled computerised systems used in GxP activities are subject to the current Annex 11, 21 CFR Part 11 where applicable, and the relevant predicate rules. Other legislation, such as the EU Artificial Intelligence Act (Regulation (EU) 2024/1689), may also apply depending on the use case and is outside the scope of this paper.

Important note on Regulatory status, October 2026: Draft Annex 22 remains non-final. The July 2025 consultation draft excludes dynamic, adaptive and probabilistic models, including GenAI/LLMs, from critical GMP applications. Following stakeholder feedback, EMA held a multistakeholder workshop in June/July 2026 to explore whether such models could be supported through a risk-based approach with appropriate controls and safeguards. The final regulatory position remains under development.

What the July 2025 consultation draft proposes

- **Critical applications.** The draft focuses on AI models used in critical GMP applications — those with a direct impact on patient safety, product quality, or data integrity. It proposes that only static models (which do not adapt during use) with deterministic output be used in such applications, and indicates that dynamic, continuously learning, and probabilistic models should not be.
- **Generative AI.** The draft indicates that generative AI and large language models should not be used in critical GMP applications, and that in non-critical applications a qualified person remains responsible for the output.
- **Intended use.** The intended use is documented and approved by process subject-matter experts, including characterisation of the input data, known limitations, and potential bias.
- **Acceptance criteria and test data.** Performance metrics and acceptance criteria are defined before testing, and the model should perform at least as well as the process it replaces. Test data should be representative, sufficient, correctly labelled, and independent of the training data.
- **Explainability, confidence, and operation.** For critical applications, the draft expects explainability and confidence information, together with change control of the model, ongoing performance monitoring, and human review where needed.

How the platform supports the draft expectations

Draft Annex 22 theme	Platform control that can support it	Decision that stays with people
Criticality classification	A register of AI use cases; policy that blocks deployment of unclassified models, or of critical models without the required approvals.	Classifying each use case as critical or non-critical (Quality with the process owner).
Intended use and acceptance criteria	Model registry entries linked to the approved intended-use and acceptance-criteria documents.	Subject-matter-expert approval of intended use and criteria.
Test-data independence	Dataset versioning and lineage showing the training and test datasets and their separation.	Judging whether test data are representative and correctly labelled.
Locked models and change control	Versioned, immutable model artefacts deployed only through controlled pipelines.	Approving model changes and the scope of re-testing.
Explainability and confidence	Explanation and confidence outputs recorded alongside each result.	Interpreting explanations, and approving confidence thresholds.
Performance monitoring	Drift and input-data monitoring with alerts to named owners.	Investigating alerts, and deciding to suspend, retrain, or retire a model.
Human review	A workflow that requires, attributes, and records human review before results are used.	The review decision, and the qualification of the reviewer.

Generative assistants used in non-critical roles, such as drafting or summarising, still need governance: approved data sources, access controls that respect existing permissions, and a clear rule that a qualified person reviews the output before it enters a GxP record. Organisations should classify AI use cases now, and gap-assess them against the draft, so they are ready when the final text is published.

6. Risks and Mitigations

> **The model fails quietly if its own controls are weakly governed. The risks that matter most are loss of trust in the evidence, inheritance applied without assessment, and exceptions that become the norm.**

Likelihood and impact ratings are illustrative. Each organisation should rate these risks within its own quality risk-management process under ICH Q9(R1), using its own scales. Accountable owners follow the roles defined in Paper 1.

Risk	Likelihood	Impact	Mitigation	Early-warning indicators	Accountable owner
Loss of evidence-store integrity or availability	Medium	Very high	Validate the store as a GxP system; immutable storage; segregation of duties; integrity checks; tested restore; reviewed break-glass access.	Ingestion failures; gaps in expected evidence volume; failed integrity checks; manual evidence uploads.	QA/CSV, with Platform Engineering responsible
False assurance from inherited controls	Medium	Very high	Require workload-level intended-use and risk assessment. Confirm that inherited controls are applicable and effective in the application context. Completeness of platform evidence must not be treated as completeness of application validation.	Workloads released without documented control applicability and intended-use assessments, unresolved inheritance exceptions, gaps between platform evidence and application-specific validation requirements.	Business/Process Owner + QA/CSV
Inheritance applied without workload assessment	Medium	High	Require an approved control inheritance record before go-live; re-assess on change.	Workloads in GxP use without an approved inheritance record.	QA/CSV
Exemption sprawl	High	High	Owner, rationale, compensating control, and expiry for every exemption; regular Exemption Review forum; no renewal without fresh justification.	Open, expired, and repeatedly renewed exemptions; share of deployments relying on exemptions.	QA/CSV, through the Control Board
Policy-as-code drifting from regulatory intent	Medium	High	Requirement-to-policy traceability; QA approval of policy changes; tests against compliant and non-compliant cases.	Policies without a linked requirement; policy changes without test evidence.	QA/CSV (intent); Platform Engineering (implementation)
Supplier change outpacing assessment	Medium	High	Pre-defined criteria for impact assessment; monitored change notifications; requalification triggers.	Unassessed change notices older than the agreed period.	Platform Engineering, with QA/CSV approval
Automation bias in review	Medium	High	Define what reviewers must examine and record; train reviewers; independent sample checks.	Reviews that consistently find nothing; implausibly short review times.	QA/CSV
Inspector unfamiliarity with the evidence model	Medium	High	Inspector narrative; mapping to familiar artefacts; mock inspections; trained presenters.	Mock-inspection findings; difficulty producing readable copies.	QA/CSV
AI use case misclassified as non-critical	Medium	High	Documented classification criteria; Quality approval; periodic re-classification.	AI use cases without a recorded classification.	QA/CSV, with the Business Process / System Owner
Platform team becomes a bottleneck	High	Medium	Productised golden paths; self-service within guardrails; agreed service levels.	Growing onboarding lead time and backlog.	Platform Engineering
Loss of CSV knowledge during transition	Medium	High	Pair CSV specialists with engineers; document control intent and rationale; joint training.	Controls without documented rationale; key-person dependency.	QA/CSV

Risk	Likelihood	Impact	Mitigation	Early-warning indicators	Accountable owner
Dependence on a single supplier	Medium	Medium	Separate control objectives from services; portability assessment; exit provisions that keep data readable for the retention period.	Critical services without an exit assessment.	Business Process / System Owner

The risks to watch most closely

The evidence store is the backbone of the model. If its integrity or availability is in doubt, confidence in every platform-generated record is lost, and the organisation must fall back on reconstruction. Early-warning indicators should be reviewed in the quarterly Assurance Review described in Paper 1 and treated as quality-significant signals, not only as operational metrics.

Inheritance without assessment and exemption sprawl are equally damaging because they hollow out the model from within: a platform can look compliant while workloads rely on controls that were never assessed for their use, or operate through exceptions that never expire. The Control Board should set thresholds that trigger escalation — for example, any workload in GxP use without an approved inheritance record, or any exemption on a critical control beyond its approved window. The aim is not to eliminate exceptions, but to keep them visible, time-bound, justified, and actively driven to closure.

7. Conclusion and Way Forward

> **Shift-Left CSV can meet existing regulatory expectations through different evidence, not lower standards, when implemented with appropriate governance, intended-use validation and accountable Quality oversight.**

This paper has mapped the Shift-Left CSV model to current regulatory requirements for GxP computerised systems and separately considered emerging expectations from the draft revisions to Annex 11 and Chapter 4, as well as the proposed Annex 22. For CSV, Quality, and Regulatory teams, the practical next steps are:

- **Map your current validation procedure** to the deliverables in Section 3.1, and decide which content will be platform-generated, and which will remain document-based.
- **Define the control inheritance record** and its approval route before the first workload goes live.
- **Classify evidence records** as GxP or supporting records, and validate the evidence store accordingly.
- **Write the inspector narrative** and test it in a mock inspection on the pilot workload.
- **Gap-assess against the draft revised Annex 11, Chapter 4 and proposed Annex 22** now, and update the assessment when the final texts are published.

Paper 1 sets out the operating model, and Paper 2 the architecture that realises it. This paper completes the series by connecting both to the regulatory and inspection reality that CSV and Quality teams work in. The destination is not compliance by architecture, but more current and repeatable risk-based assurance: engineered controls provide evidence, and people remain accountable for intended use, residual risk, exceptions, change impact, and the final Quality decision.

8. References and Regulatory Sources

Document / Guidance	Version / Date	Regulatory status	Official source
EU GMP Annex 11 – Computerised Systems	January 2011	In force	European Commission
EU GMP Chapter 4 – Documentation	January 2011	In force	European Commission
EU GMP Annex 15 – Qualification and Validation	October 2015	In force	European Commission
21 CFR Part 11 – Electronic Records; Electronic Signatures	Current regulation	In force	eCFR – US Government
FDA – Part 11, Electronic Records; Electronic Signatures: Scope and Application	August 2003	Final guidance – nonbinding	FDA
FDA – Data Integrity and Compliance with Drug CGMP: Questions and Answers	December 2018	Final guidance – nonbinding	FDA
ICH Q9(R1) – Quality Risk Management	January 2023	Final guideline – EU implemented	ICH
PIC/S PI 041-1 – Good Practices for Data Management and Integrity in Regulated GMP/GDP Environments	July 2021	Published regulatory guidance	PIC/S
ISPE GAMP 5 – A Risk-Based Approach to Compliant GxP Computerized Systems, Second Edition	July 2022	Industry guidance – nonbinding	ISPE
Draft revised EU GMP Chapter 4 – Documentation	July 2025	Draft – not adopted	European Commission
Draft revised EU GMP Annex 11 – Computerised Systems	July 2025	Draft – not adopted	European Commission
Draft EU GMP Annex 22 – Artificial Intelligence	July 2025	Draft – not adopted	European Commission
EMA – Multistakeholder Workshop Report on Annex 22	October 2026	Published report – nonbinding	EMA

Regulatory status reflects information available as of October 2026. Draft guidance and consultation documents are included for forward-looking context and are not requirements currently in force.